TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Cisco SD-WAN zero-day used to deploy KeyDrift key-stealing malware; overlap with Volt Typhoon infrastructure

From **Cybersecurity Briefing - 2026-10-30** · 2026-10-29 to 2026-10-30 (last 24 hours; Indianapolis and State of Indiana swept back to 2026-10-25) · Briefing generated 2026-10-30

REPORT ID	VERSION	HANDLING	BRIEFING SECTION
CTI-20261030-04	1.0 · 2026-10-30 10:08 EDT	TLP:CLEAR	United States
ORIGINAL PUBLISHED	**LAST UPDATE**	**CVES**	**ANALYST**
2026-10-28	2026-10-29	CVE-2026-20127 (CVSS 10.0), CVE-2022-20775	Nick Sturgeon

NATION-STATE | CRITICAL | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

On 2026-10-28 Cisco Talos published research on a cluster it tracks as UAT-11473. The group exploited CVE-2026-20127, a CVSS 10.0 peering-authentication bypass in Cisco Catalyst SD-WAN Controller (formerly vSmart), Manager (formerly vManage) and Validator (formerly vBond), and then installed a custom malware framework Talos calls KeyDrift [S1] [S5] [S6]. KeyDrift runs inside the SD-WAN control-plane daemon vdaemon. Its PolyFlame module is a backdoor and relay that can also act as an intermediate command-and-control node for other peers. Its LittleFilch module hooks OpenSSL SSL_read to read decrypted control messages and pulls out peer IP identifiers plus a 32-byte field that Talos assesses is AES-256 IPsec data-plane key material. LittleFilch RSA-encrypts these records, stages them in /var/tmp/vdaemon.bin and sends them out over UDP in a DTLS-style record [S1] [S3]. The targets Talos names are space and satellite services, defense and aerospace technology, and policy research organizations [S1].

Talos assesses with high confidence that UAT-11473's infrastructure 'overlaps considerably' with Silent Train, the covert multi-hop relay network that Lumen's Black Lotus Labs attributes to the China-linked Volt Typhoon. Talos does not say the two are the same group [S1] [S2]. On the same day, Lumen separately reported that Volt Typhoon was exploiting Cisco Catalyst SD-WAN by late 2025, before disclosure, and kept exploiting it after Cisco's February 2026 advisory [S4] [S10]. Lumen's report does not mention KeyDrift or UAT-11473 [S2]. In February, Talos had tied exploitation of the same CVE to a different cluster, UAT-8616, with activity going back to 2023. That chain added rogue peers, downgraded software to exploit CVE-2022-20775 for root access, and then restored the original version [S8] [S9]. Public sources do not say how UAT-8616 and UAT-11473 relate.

The flaw was patched and added to CISA KEV on 2026-02-25, and CISA issued Emergency Directive 26-03 the same day [S5] [S7] [S9]. EPSS rates it at about 0.89, in the 99.8th percentile [S12]. Talos describes the KeyDrift activity as historical but gives no intrusion dates [S1]. Patching closes the entry point but does not remove an implant that is already persistent through runit service scripts. It also cannot undo the theft of data-plane keys [S1]. No network IOCs (IPs, domains, hashes) have been published. Talos says PolyFlame takes its tasking in-band over SD-WAN control traffic and has no hardcoded C2 [S1].

What to do: confirm every Controller, Manager and Validator is on a fixed release. Hunt each one for the KeyDrift file artifacts and the UAT-8616 log indicators. Validate every control-connection peering event against inventory. Run 'request admin-tech' and open a Cisco TAC case if anything looks wrong. Rotate SD-WAN keys, certificates and admin credentials, and rebuild any controller where root-level compromise is found [S1] [S5] [S8] [S11].

Key judgments

VERY LIKELY · HIGH CONFIDENCE
Patching to a fixed release very likely does not remove KeyDrift from a controller that was already compromised. The implant persists through modified runit service scripts and a malicious aaamgr service. Any controller that was exposed before it was patched needs a forensic check, not just an upgrade. [S1] [S5]

LIKELY · MODERATE CONFIDENCE
More victims are likely to be found in the coming weeks. Talos has released Snort coverage and file-level artifacts, Cisco updated its advisory on 2026-10-28, and Lumen has notified hundreds of Silent Train victims. [S1] [S4] [S5]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE
Whether stolen data-plane keys were used to decrypt captured fabric traffic is a roughly even chance. Using them would require separate access to the traffic path, and no public source confirms that decryption happened. [S1] [S3]

VERY LIKELY · MODERATE CONFIDENCE
Volt Typhoon-linked operators will very likely keep using zero-days against network management and control-plane platforms over the next 6 to 12 months. Lumen documents at least four zero-day campaigns of this kind (Versa Director, N-able N-central, Cisco Catalyst SD-WAN, VeloCloud Orchestrator) and a likely fifth (Quest KACE). [S4] [S2]

UNLIKELY · LOW CONFIDENCE
It is unlikely that public reporting in the near term will firmly establish UAT-11473 as Volt Typhoon itself rather than a separate actor using shared covert infrastructure. Talos frames the link only as infrastructure overlap, and Lumen does not mention the cluster. [S1] [S2] [S4]

INDICATORS OF COMPROMISE

All indicators are host artifacts, log strings and port or protocol patterns from Cisco Talos (KeyDrift, 2026-10-28; UAT-8616, 2026-02-25), the Cisco advisory and Lumen's Silent Train report. No IP addresses, domains or file hashes for KeyDrift have been published, and Talos says PolyFlame has no hardcoded network endpoints. Derived entries are marked and explained.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/var/tmp/vdaemon.bin`	LittleFilch staging file holding RSA-encrypted records of peer IPs and assessed AES-256 data-plane key material.	REPORTED		[S1] [S3]
filepath	`/var/tmp/vdaemon.conf`	LittleFilch runtime config with local and remote UDP endpoints. Deleted after it is read; Talos did not recover it.	REPORTED		[S1]
filepath	`/tmp/system-vdaemon`	File where conf_sshd writes the vdaemon PIDs it enumerates before injection.	REPORTED		[S1]
filepath	`/etc/sv/aaamgr/`	Directory of a malicious runit service that launches the packed aaamgrd PolyFlame loader.	REPORTED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/etc/sv/aaamgr/run`	Runit starts a service through its 'run' script, so the malicious aaamgr service almost certainly has a run file in this directory. Inferred from the reported service directory.	DERIVED		[S1]
filepath	`/etc/sv/sshd/run`	Talos says the actor modified the sshd runit run script to remount /rootfs.rw executable and start conf_sshd before the real sshd. The path is inferred from the reported /etc/sv/sshd/ directory and runit conventions.	DERIVED		[S1]
filepath	`/rootfs.rw`	Writable overlay that the trojanized run scripts remount as executable. aaamgrd deletes the sshd and login PAM configs on this overlay first.	REPORTED		[S1]
filename	`libdssl.so`	PolyFlame shared object injected into vdaemon. It interposes on recvfrom, sendto, getpeername, dlopen, dlsym and mprotect.	REPORTED		[S1]
filename	`libcommon.so`	LittleFilch module that hooks OpenSSL SSL_read inside vdaemon.	REPORTED		[S1]
filename	`rsshd`	ptrace-based injector that loads libdssl.so into vdaemon by PID. The name imitates sshd.	REPORTED		[S1]
filename	`conf_sshd`	Shell script that finds vdaemon PIDs and calls rsshd. Launched in the background from the modified sshd run script.	REPORTED		[S1]
filename	`aaamgrd`	Packed, statically linked ELF64 loader with an RC4-encrypted PolyFlame payload. Uses direct syscalls, exits if TracerPid shows a debugger, and was timestomped.	REPORTED		[S1]
command	`touch --reference=`	Timestomping: the operator copied timestamps from legitimate files onto implant files.	REPORTED		[S1]
command	`chmod --reference=`	Copies permissions from legitimate files onto implant files, used together with touch --reference.	REPORTED		[S1]
command	`mount -o remount,exec /rootfs.rw`	Talos says the run scripts remount /rootfs.rw executable but does not quote the exact command line. This is the standard Linux form of that action and is useful as a hunt pattern. Exact syntax unconfirmed.	DERIVED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`Unexpected ptrace attach to vdaemon from a non-Cisco process; unknown shared objects (libdssl.so, libcommon.so) mapped in vdaemon's /proc/<pid>/maps`	Follows from the reported ptrace injection and library interposition. Compare vdaemon's loaded libraries against a known-good controller.	DERIVED		[S1]
http-request	`Outbound UDP from an SD-WAN controller to a non-fabric host with a DTLS 1.2 application-data record header (content type 0x17, version 0xFEFD)`	Talos says LittleFilch exfiltrates over UDP in a DTLS 1.2 application-data style record. The byte pattern comes from the DTLS 1.2 record format. Legitimate controller DTLS goes to fabric peers, so the useful signal is the destination.	DERIVED		[S1]
other	`control-connection-state-change new-state:up peer-type:vmanage`	vdaemon log event to validate. Unexpected timing, unknown public IPs or unexpected peer types point to a rogue peer added through CVE-2026-20127.	REPORTED	2026-02-25	[S8] [S5]
other	`Accepted publickey for vmanage-admin`	Entry to audit in /var/log/auth.log when the source IP is not one of the System IPs listed under Devices > System IP.	REPORTED	2026-02-25	[S5]
other	`Software upgrade not confirmed. Reverting to previous software version`	Log string tied to the unauthorized downgrade and restore the UAT-8616 chain used to exploit CVE-2022-20775.	REPORTED	2026-02-25	[S8]
other	`system-login-change severity-level:minor ... user-name:"root"`	Root login event in SD-WAN logs listed by Talos as a post-exploitation indicator.	REPORTED	2026-02-25	[S8]
other	`/../../ in a username field`	Path traversal in usernames, which Talos lists as a sign of CVE-2022-20775 exploitation.	REPORTED	2026-02-25	[S8]
filepath	`/home/root/.ssh/authorized_keys`	Unexpected keys here point to root SSH persistence (UAT-8616 indicator).	REPORTED	2026-02-25	[S8]
filepath	`/home/vmanage-admin/.ssh/authorized_keys`	Unexpected keys for the internal vmanage-admin account (UAT-8616 indicator).	REPORTED	2026-02-25	[S8]
filepath	`/etc/ssh/sshd_config`	PermitRootLogin set to yes is a reported indicator.	REPORTED	2026-02-25	[S8]
port	`22/tcp`	Cisco's temporary mitigation for on-prem deployments restricts this port to known controller IPs and approved hosts.	REPORTED		[S5]
port	`830/tcp`	NETCONF over SSH. Restrict it the same way as port 22. The exploit gives NETCONF access to fabric configuration.	REPORTED		[S5] [S6]
port	`2222/tcp`	Example SSH port Lumen observed in Silent Train relay hops. Not specific to KeyDrift.	REPORTED		[S4]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
port	`14737/tcp`	Example SSH port Lumen observed in Silent Train relay hops. Not specific to KeyDrift.	REPORTED		[S4]
other	`Snort SIDs 65938, 65958`	Talos coverage for CVE-2026-20127 exploitation.	REPORTED	2026-02-25	[S1] [S8]
other	`Snort 2 SIDs 67387-67416; Snort 3 SIDs 7:44-7:73`	Talos coverage for KeyDrift malicious artifacts.	REPORTED	2026-10-28	[S1]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The attacker reaches a Catalyst SD-WAN Controller, Manager or Validator over the network and sends crafted peering requests that bypass authentication (CVE-2026-20127). This logs them in as an internal high-privilege, non-root account with NETCONF access, and lets them add a rogue peer [S5] [S6]. In the earlier UAT-8616 chain, the actor reached root by downgrading the software to a release vulnerable to CVE-2022-20775 and then restoring the original version. They also created and deleted accounts and truncated logs [S8] [S9]. In UAT-11473 intrusions, the actor modified the sshd runit run script and added a malicious aaamgr runit service. These remount the /rootfs.rw overlay as executable. conf_sshd then enumerates vdaemon PIDs, and the rsshd injector uses ptrace to load PolyFlame (libdssl.so) into vdaemon. A packed aaamgrd loader with anti-debug checks offers a second path and deletes PAM configs [S1]. PolyFlame interposes on socket and DTLS functions to receive tasking in-band over control traffic. It runs shell commands, reads and writes files, and relays commands to other peers as an intermediate C2. It checks an MD5 of the current date to limit when it runs. LittleFilch (libcommon.so) hooks SSL_read, takes peer transport and system IPs plus 32-byte assessed AES-256 data-plane keys from OMP messages, RSA-encrypts them to /var/tmp/vdaemon.bin, and exfiltrates them over UDP disguised as DTLS 1.2 [S1]. According to Lumen, operator traffic arrives through Silent Train, a rotating chain of four to six compromised SOHO, IoT and enterprise devices with disposable VPS endpoints. Sessions are short and artifacts are cleaned up afterward [S4] [S10].

Threat actor

UAT-11473 · also tracked as Infrastructure overlap with Volt Typhoon (Silent Train network)

Attribution confidence: Low · **Motivation:** Espionage and likely pre-positioning. The targets are space and satellite, defense and aerospace, and policy research. Lumen assesses that Volt Typhoon's wider activity combines espionage with pre-positioning for a possible Indo-Pacific crisis. · **Suspected origin:** Suspected China nexus, based on infrastructure overlap with Volt Typhoon (PRC-linked). Not confirmed for UAT-11473 itself.

Talos has high confidence in the infrastructure overlap but does not equate UAT-11473 with Volt Typhoon [S1] [S2]. Lumen separately attributes Cisco SD-WAN exploitation from late 2025 to Volt Typhoon but does not name KeyDrift or UAT-11473 [S2] [S4]. Talos tracked February 2026 exploitation of the same CVE as UAT-8616 (active since at least 2023) and did not attribute it to a known group [S8] [S9]. BleepingComputer says recent research has linked the UAT-8616 activity to Volt Typhoon [S3]. Attribution confidence here is Low because the identity link rests on infrastructure overlap only.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Initial Access	T1190 Exploit Public-Facing Application	Crafted peering requests exploit CVE-2026-20127 to bypass authentication on Catalyst SD-WAN Controller, Manager or Validator. [S1] [S5] [S8]	Validate every control-connection-state-change peer-type:vmanage event against inventory. Deploy Snort SIDs 65938 and 65958.
Persistence	T1078 Valid Accounts	The exploit grants the internal high-privilege vmanage-admin context. UAT-8616 also created, used and deleted malicious accounts. [S5] [S8]	Alert on 'Accepted publickey for vmanage-admin' from IPs that are not fabric System IPs.
Privilege Escalation	T1068 Exploitation for Privilege Escalation	Software downgrade to a release vulnerable to CVE-2022-20775 (path traversal) to get root, then restore of the original version (UAT-8616 chain). [S8] [S9]	Look for 'Software upgrade not confirmed. Reverting to previous software version' and /../../ in username fields.
Persistence	T1037 Boot or Logon Initialization Scripts	Trojanized sshd runit run script remounts /rootfs.rw executable and launches conf_sshd before the real sshd. [S1]	Compare /etc/sv/*/run scripts against a known-good image or checksums from Cisco TAC.
Persistence	T1543 Create or Modify System Process	Malicious runit service under /etc/sv/aaamgr/ runs the packed aaamgrd loader. [S1]	List runit services and look for unexpected aaamgr service directories or binaries.
Defense Evasion	T1036.004 Masquerade Task or Service	Implant components named rsshd, conf_sshd and aaamgrd imitate legitimate sshd and aaamgr services. [S1]	Hunt for those exact file names. Check binary hashes of service executables against vendor images.
Defense Evasion	T1055.008 Process Injection: Ptrace System Calls	rsshd uses ptrace to inject libdssl.so into vdaemon by PID. [S1]	Check vdaemon's mapped libraries for libdssl.so or libcommon.so. Watch for ptrace activity against vdaemon.
Defense Evasion	T1574.006 Hijack Execution Flow: Dynamic Linker Hijacking	PolyFlame interposes on recvfrom, sendto, getpeername, dlopen, dlsym and mprotect through dlsym(RTLD_NEXT). [S1]	Collect memory or admin-tech output and look for unexpected interposed libraries in vdaemon.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	PolyFlame command 0x100 runs /bin/sh -c. conf_sshd is a shell script. [S1]	Look for shell child processes of vdaemon.
Defense Evasion	T1027.002 Obfuscated Files or Information: Software Packing	aaamgrd is a packed static ELF with an RC4-encrypted embedded payload and no section headers. [S1]	Flag ELF files on controllers that have no section headers or a single RWE segment.
Defense Evasion	T1497.001 Virtualization/Sandbox Evasion: System Checks	aaamgrd reads TracerPid from /proc/<pid>/status and exits if a debugger is attached. [S1]	Mainly matters for analysis. Have analysts expect anti-debug when handling samples.
Defense Evasion	T1556.003 Modify Authentication Process: Pluggable Authentication Modules	aaamgrd deletes writable-overlay PAM configs for sshd and login before remounting /rootfs.rw. This mapping is the analyst's own; Talos describes it as PAM tampering. [S1]	Check that the PAM configs for sshd and login exist and match the vendor baseline.

Tactic	Technique	Procedure observed	Detection opportunity
Defense Evasion	T1070.006 Indicator Removal: Timestomp	touch --reference and chmod --reference copy metadata from legitimate files onto implant files. [S1]	Do not trust file timestamps. Rely on hashes and content comparison.
Defense Evasion	T1070.002 Indicator Removal: Clear Linux or Mac System Logs	UAT-8616 truncated syslog, wtmp, lastlog, cli-history and bash_history. [S8]	Alert on empty or unusually small logs. Forward logs off-box so truncation can be spotted.
Credential Access	T1040 Network Sniffing	LittleFilch hooks SSL_read in vdaemon to read decrypted OMP control messages and extract peer IPs and assessed AES-256 data-plane keys. [S1] [S3]	Look for libcommon.so in vdaemon and the presence of /var/tmp/vdaemon.bin.
Command and Control	T1573.001 Encrypted Channel: Symmetric Cryptography	PolyFlame uses AES for in-band C2, and aaamgrd uses RC4 for its payload. LittleFilch records are RSA-encrypted. [S1]	In-band C2 is hard to see on the network. Focus on host artifacts.
Command and Control	T1090.003 Proxy: Multi-hop Proxy	Silent Train chains of four to six compromised SOHO, IoT and enterprise devices with VPS endpoints, using SSH chaining and Chisel/FRP tunnels. PolyFlame also relays between peers as an intermediate C2. [S1] [S4]	Watch for management-plane logins from residential or SOHO IP space. Check edge devices for Chisel or FRP.
Exfiltration	T1048 Exfiltration Over Alternative Protocol	LittleFilch sends RSA-encrypted records over UDP in a DTLS 1.2 application-data style record to endpoints from vdaemon.conf. [S1]	Alert on controller UDP flows to destinations outside the fabric peer list.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

KeyDrift file artifacts on SD-WAN controllers (Linux file events) `SIGMA`

```
title: KeyDrift Artifacts on Cisco Catalyst SD-WAN Controller
status: experimental
logsource:
  product: linux
  category: file_event
detection:
  sel_path:
    TargetFilename|endswith:
      - '/var/tmp/vdaemon.bin'
      - '/var/tmp/vdaemon.conf'
      - '/tmp/system-vdaemon'
      - '/libdssl.so'
      - '/libcommon.so'
      - '/rsshd'
      - '/conf_sshd'
      - '/aaamgrd'
  sel_svc:
    TargetFilename|startswith: '/etc/sv/aaamgr/'
  condition: sel_path or sel_svc
falsepositives:
  - A legitimate Cisco file with a matching name (verify with Cisco TAC; libcommon.so may be a common library name)
level: high
```

SD-WAN appliances seldom produce file-event telemetry. Most teams will run this as a manual check against 'request admin-tech' bundles or a file listing taken from a root shell under TAC guidance.

Rogue peering, vmanage-admin key logins and downgrade events (SD-WAN syslog) `SPLUNK SPL`

```
index=network sourcetype=cisco:sdwan* ("control-connection-state-change" "new-state:up" "peer-type:vmanage") OR
("Accepted publickey for vmanage-admin") OR ("Software upgrade not confirmed. Reverting to previous software version")
OR ("system-login-change" "user-name" "root") OR "/../../"
| rex "from (?<src_ip>\d{1,3}(?:\.\d{1,3}){3})"
| lookup sdwan_system_ips ip AS src_ip OUTPUT device_name
| where isnull(device_name)
| stats count min(_time) AS first max(_time) AS last values(_raw) AS events BY host src_ip
```

Requires the controllers to send syslog off-box and a lookup (sdwan_system_ips) built from Devices > System IP. Peering events need manual validation, because legitimate re-peering after maintenance will also match.

Possible LittleFilch UDP exfiltration from SD-WAN controllers `SURICATA`

```
alert udp $SDWAN_CONTROLLERS any -> !$SDWAN_FABRIC any (msg:"Possible KeyDrift LittleFilch DTLS-style UDP exfil from
SD-WAN controller to non-fabric host"; content:"|17 fe fd|"; depth:3; threshold:type limit, track by_src, count 1,
seconds 3600; classtype:trojan-activity; sid:9002601; rev:1;)
```

Define $SDWAN_CONTROLLERS and $SDWAN_FABRIC (every legitimate edge, controller and cloud-hosted peer). The rule matches a DTLS 1.2 application-data header to any destination outside the fabric. Expect noise until the fabric list is complete.

Access to controller SSH/NETCONF from non-allowlisted sources `KQL`

```
CommonSecurityLog
| where TimeGenerated > ago(30d)
| where DestinationIP in (dynamic(["<controller_ip_1>","<controller_ip_2>"]))
| where DestinationPort in (22, 830)
| where SourceIP !in (dynamic(["<approved_admin_ip>","<controller_system_ip>"]))
| summarize Connections=count(), FirstSeen=min(TimeGenerated), LastSeen=max(TimeGenerated) by SourceIP, DestinationIP,
DestinationPort, DeviceAction
| order by Connections desc
```

Based on Cisco's temporary mitigation of restricting ports 22 and 830. Replace the placeholders with your controller and approved-host IPs. Any allowed connection from an unknown source should be investigated.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Cisco Catalyst SD-WAN Controller (vSmart), Manager (vManage), Validator (vBond): On-Prem, Hosted SD-WAN Cloud, Cisco Managed, FedRAMP	All configurations on releases before the fixed versions. The CVE record lists Manager releases 17.2.4 through 20.18.2.	20.9.8.2; 20.12.5.3 or 20.12.6.1; 20.15.4.2; 20.18.2.1. Releases before 20.9 and end-of-maintenance trains (20.11, 20.13, 20.14, 20.16) must migrate to a fixed release. Check against the live advisory.	CVE-2026-20127	10.0 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H)	0.89294 (99.78th percentile, 2026-10-29)	Yes (added 2026-02-25)	2026-02-27
Cisco SD-WAN (privilege escalation used in the downgrade chain)	See Cisco advisory cisco-sa-sd-wan-priv-E6e8tEdF. Versions not verified for this report.	See Cisco advisory cisco-sa-sd-wan-priv-E6e8tEdF	CVE-2022-20775	High (score not verified)	Not retrieved	Yes (added 2026-02-25)	2026-02-27

Immediate (0–24 hours)

- Inventory every Catalyst SD-WAN Controller, Manager and Validator (including any run for clients) and confirm each is on a fixed release from the Cisco advisory. `IT OPS` [S5]
- On on-prem deployments, restrict TCP 22 and 830 on controllers to known controller IPs and approved admin hosts with ACLs, security groups or firewall rules. `IT OPS` [S5]
- Hunt for KeyDrift artifacts (/var/tmp/vdaemon.bin, /var/tmp/vdaemon.conf, /tmp/system-vdaemon, /etc/sv/aaamgr/, libdssl.so, libcommon.so, rsshd, conf_sshd, aaamgrd) and for modified /etc/sv/sshd/run scripts. `SOC` [S1]
- Audit /var/log/auth.log for 'Accepted publickey for vmanage-admin' from unknown IPs. Validate every control-connection peering event (timestamp, public IP, system IP, peer type) against inventory. `SOC` [S5] [S8]
- Run 'request admin-tech' on each control component and preserve the output before making changes. Open a Cisco TAC case if anything looks suspicious. `IT OPS` [S5] [S1]
- Deploy Talos Snort SIDs 65938 and 65958 (exploit) and 67387-67416 / 7:44-7:73 (KeyDrift artifacts) where Snort or Cisco Secure Firewall is in use. `SOC` [S1]

Short term (1–7 days)

- If compromise is found or cannot be ruled out, rebuild the affected controllers from known-good images instead of cleaning them in place. ED 26-03 requires a rebuild when root access is detected. `IT OPS` [S11] [S1]
- Rotate SD-WAN fabric key material, controller and edge certificates, vmanage-admin and local admin credentials, and SSH authorized_keys, on the assumption that data-plane keys and session identifiers may have been taken. `IT OPS` [S1] [S8]
- Check for root SSH persistence (/home/root/.ssh/authorized_keys, PermitRootLogin yes), unexpected accounts, unauthorized downgrade messages and truncated logs. `SOC` [S8]
- Forward controller syslog and auth logs to the SIEM with long retention so peering and login events can be reviewed after the fact. `SOC` [S4] [S11]
- Brief leadership on possible exposure of encrypted WAN traffic, and decide whether legal, client or regulatory notification is needed if keys are confirmed stolen. `LEADERSHIP` [S1]

Long term

- Apply the Cisco Catalyst SD-WAN hardening guide and keep management interfaces off the internet behind VPN, jump hosts or a dedicated management network. `IT OPS` [S5] [S4]
- Patch management and control-plane platforms (SD-WAN, RMM, orchestration, ITSM such as N-central, KACE, VeloCloud, Versa) on an emergency track, because Volt Typhoon-linked operators target this class of system. `LEADERSHIP` [S4]
- Get file-integrity baselines or vendor checksums for appliance service scripts and binaries so implants can be found without relying on timestamps. `IT OPS` [S1]
- Review CISA AA24-038A and AA26-113A guidance and retire or isolate end-of-life SOHO devices that could serve as Silent Train relays. `LEADERSHIP` [S4]

Workarounds & compensating controls

- Until patching is confirmed, allowlist port 22 and 830 sources on controllers. Cisco calls this a temporary mitigation only; there is no workaround. `IT OPS` [S5]
- Alert on controller UDP traffic to any destination outside the fabric peer list, and on management logins from residential or SOHO IP space. `SOC` [S1] [S4]
- For hosted or Cisco-managed deployments, ask Cisco to confirm the guardrails and patch status, and request peering logs for review. `IT OPS` [S5]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] Cisco Talos: UAT-11473 and KeyDrift (historical Cisco SD-WAN exploitation)
Published 2026-10-28 · **A2** Completely reliable, probably true
Primary technical source for KeyDrift components, artifacts, ATT&CK mapping and Snort SIDs. No network IOCs or hashes published.

[S2] SecurityWeek: Cisco SD-WAN Zero-Day Exploitation Tied to Volt Typhoon's Silent Train Network
Published 2026-10-29 · **B2** Usually reliable, probably true
Briefing source. Notes that Lumen's report does not mention KeyDrift or UAT-11473.

[S3] BleepingComputer: Hackers exploit Cisco SD-WAN flaw to deploy custom KeyDrift malware
Published 2026-10-29 · **B2** Usually reliable, probably true
Briefing source. Summarizes Talos and links UAT-8616 to Volt Typhoon via 'recent research'; that claim is not independently confirmed here.

[S4] Lumen Black Lotus Labs: Silent Train: Volt Typhoon operational framework
Published 2026-10-28 · **A2** Completely reliable, probably true
The page shows no explicit date; the publication date comes from SecurityWeek and Zero Day. Source for Volt Typhoon SD-WAN exploitation by late 2025. No IPs, domains or hashes.

[S5] Cisco PSIRT: Cisco Catalyst SD-WAN Controller Authentication Bypass Vulnerability (cisco-sa-sdwan-rpa-EHchtZk)
Published 2026-02-25 · **A1** Completely reliable, confirmed by other sources
Vendor advisory, updated 2026-10-28 (v2.1 Final). Fixed releases, mitigation and IoC validation steps. The fixed-release table rendered poorly, so verify on the live page.

[S6] CVE Program (MITRE): CVE-2026-20127 record
Published 2026-02-25 · **A1** Completely reliable, confirmed by other sources
CVSS 10.0, CWE-287. Updated 2026-06-16. The affected list names only Manager, though the description covers all three components.

[S7] CISA: Known Exploited Vulnerabilities Catalog (JSON feed)
Published 2026-02-25 · **A1** Completely reliable, confirmed by other sources
CVE-2026-20127 and CVE-2022-20775 added 2026-02-25, due 2026-02-27, with ED 26-03 required actions.

[S8] Cisco Talos: UAT-8616 exploitation of Cisco Catalyst SD-WAN (CVE-2026-20127)
Published 2026-02-25 · **A2** Completely reliable, probably true
Original zero-day write-up. Activity since 2023, downgrade plus CVE-2022-20775 chain, log-based indicators.

[S9] SecurityWeek: Cisco Patches Catalyst SD-WAN Zero-Day Exploited by Highly Sophisticated Hackers
Published 2026-02-26 · **B2** Usually reliable, probably true
February disclosure coverage. ED 26-03 and KEV additions, fixed versions.

[S10] Zero Day (Kim Zetter): Silent Train: Volt Typhoon's sophisticated infection chain into US targets exposed
Published 2026-10-28 · **B2** Usually reliable, probably true
Interview with Black Lotus Labs on espionage plus pre-positioning, victim sectors, and MSPs as targets.

[S11] Infosecurity Magazine: CISA Issues Emergency Directive Over Exploited Cisco SD-WAN Flaws
Published 2026-03-12 · **B2** Usually reliable, probably true
ED 26-03 requirements, including rebuild if root access is detected and reporting through 2026-03-23.

[S12] FIRST: EPSS API: CVE-2026-20127
Published 2026-10-29 · **A2** Completely reliable, probably true
Model-based exploitation probability 0.89294, 99.78th percentile.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2023-01-01	Earliest malicious activity Talos ties to UAT-8616 exploitation of Catalyst SD-WAN (year only; 'at least' 2023).	[S8]
2023-11-01	Black Lotus Labs begins consistently observing Silent Train activity (month only).	[S4]
2025-12-01	By late 2025, Volt Typhoon is exploiting Cisco Catalyst SD-WAN as a zero-day according to Lumen (approximate date).	[S4] [S2]
2026-02-25	Cisco discloses and patches CVE-2026-20127. Talos publishes the UAT-8616 write-up. CISA adds CVE-2026-20127 and CVE-2022-20775 to KEV and issues ED 26-03.	[S5] [S7] [S8] [S9]
2026-03-23	Final ED 26-03 reporting deadline for federal agencies.	[S11]
2026-10-28	Talos publishes UAT-11473/KeyDrift research. Lumen publishes Silent Train report. Cisco updates the advisory to v2.1 Final, linking the Talos research.	[S1] [S4] [S5] [S10]
2026-10-29	SecurityWeek and BleepingComputer report the KeyDrift and Volt Typhoon overlap.	[S2] [S3]

Relevance to Indianapolis, Indiana & managed clients

Cisco Catalyst SD-WAN is widely used to connect branch offices, clinics, plants and campuses. In Indiana that includes multi-site health systems, county and municipal governments, school districts, and manufacturers with distributed plants. The sectors Talos and Lumen name match parts of the Indiana economy: defense and aerospace suppliers in the state's defense industrial base, universities with ROTC programs and defense-funded research, telecom and utility operators, and MSPs and IT providers, which Lumen lists explicitly as Volt Typhoon targets [S1] [S4] [S10]. Indiana was not among the most-targeted states (Hawaii, California and Texas) [S4], but MSP and supply-chain access lets an actor reach across state lines. For managed IT service clients, the main risks are that a provider-run SD-WAN Manager covers many client fabrics, and that stolen data-plane keys could expose traffic between sites. Providers should confirm patch level and run the artifact hunt on every client controller they manage, check with clients on Cisco-hosted deployments, and plan key and certificate rotation. Small and mid-size businesses that bought SD-WAN as a managed service should ask their provider in writing for confirmation of the fixed release and the outcome of the KeyDrift hunt.

Intelligence gaps

- No intrusion dates for the KeyDrift activity. Talos calls it historical but does not say when it occurred or when it was detected.
- No network IOCs (C2 IPs, domains) or file hashes for KeyDrift components have been published. vdaemon.conf, which holds the exfiltration endpoints, was not recovered.
- How UAT-11473 relates to UAT-8616 (the February cluster) and to Volt Typhoon has not been publicly settled.
- Number and identity of victims, and whether any are outside the named sectors (space, defense, policy research).
- Whether stolen data-plane keys were used to decrypt captured traffic, and how long keys stay valid before rekey in typical deployments.
- Whether exploitation continues against unpatched controllers after the October disclosures. Lumen says exploitation continued after February.
- Exact affected and fixed versions for CVE-2022-20775 were not verified for this report. Watch for further Cisco advisory revisions and any CISA update to ED 26-03.

Other notes

- Sources disagree on dates. Talos (UAT-8616) dates exploitation to at least 2023 and BleepingComputer repeats this, while Lumen dates Volt Typhoon's Cisco SD-WAN exploitation to late 2025. These may describe different clusters or different visibility.
- BleepingComputer says recent research has linked UAT-8616 exploitation to Volt Typhoon. Talos's February post did not attribute UAT-8616 to a known group, and the KeyDrift post does not mention UAT-8616.
- The CVE record lists only SD-WAN Manager as affected, while the Cisco advisory and CVE description cover Controller, Manager and Validator regardless of configuration. Treat all three as affected.
- A Japanese security blog found in search results claims a public proof-of-concept appeared after the February disclosure. This report did not open or verify that claim, so it is not relied on.
- Lumen lists other Volt Typhoon zero-day campaigns against management platforms: Versa Director, N-able N-central (CVE-2025-8875, CVE-2025-8876), VeloCloud Orchestrator (CVE-2026-16812) and likely Quest KACE. These deserve a parallel review where they are in use.
- CISA KEV also lists a separate Cisco SD-WAN flaw, CVE-2026-76504 (added 2026-09-30, BOD 26-04). It is unrelated to this item but adds to the SD-WAN patch backlog.

CTI-20261030-04 v1.0 · Generated 2026-10-30 10:08 EDT from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.